

Capítulo 14

Testando o sistema

14.1. Objetivos

- Entender como ocorrem ataques de negação de serviço
- Entender o que é DoS, DDoS, e DRDoS
- Entender o que é e como realizar sequestro de sessão

14.2. O que é negação de serviço?

Quem acompanha os noticiários de informática ou o próprio Boletim Anti-Vírus do InfoWester certamente já se deparou com matérias que citam ataques DoS ou ataques DDoS a sites. O objetivo deste capítulo é dar explicações sobre isso e também mostrar as consequências de tais ataques.

Durante um ataque de negação de serviço, o atacante deixa o sistema impossível de ser usado ou significativamente lento, a ponto de conseguir realizar poucas tarefas. Esses ataques podem ser realizados contra um sistema individual ou contra uma rede inteira e normalmente são realizados com sucesso.

Qualquer tipo de ataque que afete o pilar “Disponibilidade” da tríade Confidencialidade-Integridade-Disponibilidade, pode ser considerado um ataque de negação de serviço, desde puxar a tomada de alimentação de energia de um servidor, até utilizar uma rede zumbi para ataque em massa.

Na maior parte das vezes, o objetivo do atacante não conseguir acesso à informações, roubo de dados, ou tomar o controle da máquina. O objetivo é realmente causar a indisponibilidade de serviços nos sistemas do alvo, e isso pode levar a potenciais prejuízos financeiros, do ponto de vista comercial, por exemplo.

Abaixo temos alguns exemplos de ataques realizados em site conhecidos, que de alguma forma causou prejuízos financeiros aos sites atacados.

Exemplos de ataques:

- Contra DNS da Telefonica
 - ✓ Speedy
- Contra sistema de votação do BBB
 - ✓ Globo
- Contra sites de update
 - ✓ update.microsoft.com

- Contra sites grandes:
 - ✓ CNN
 - ✓ Yahoo

14.3. DoS

De acordo com a definição do CERT (Computer Emergency Response Team), os ataques DoS (Denial of Service), também denominados Ataques de Negação de Serviços, consistem em tentativas de impedir usuários legítimos de utilizarem um determinado serviço de um computador. Para isso, são usadas técnicas que podem: sobrecarregar uma rede a tal ponto em que os verdadeiros usuários dela não consigam usá-la; derrubar uma conexão entre dois ou mais computadores; fazer tantas requisições a um site até que este não consiga mais ser acessado; negar acesso a um sistema ou a determinados usuários.

Explicando de maneira ilustrativa, imagine que você usa um ônibus regularmente para ir ao trabalho. No entanto, em um determinado dia, uma quantidade enorme de pessoas "furaram a fila" e entraram no veículo, deixando-o tão lotado que você e os outros passageiros regulares não conseguiram entrar. Ou então, imagine que você tenha conseguido entrar no ônibus, mas este ficou tão cheio que não conseguiu sair do lugar por excesso de peso. Este ônibus acabou negando o seu serviço - o de transportá-lo até um local -, pois recebeu mais solicitações - neste caso, passageiros - do que suporta.

É importante frisar que quando um computador/site sofre ataque DoS, ele não é invadido, mas sim, tem apenas o serviço parado.

Os ataques do tipo DoS mais comuns podem ser feitos devido a algumas características do protocolo TCP/IP (Transmission Control Protocol / Internet Protocol), sendo possível ocorrer em qualquer computador que o utilize. Uma das formas de ataque mais conhecidas é a SYN Flooding, onde um computador tenta estabelecer uma conexão com um servidor através de um sinal do TCP conhecido por SYN (Synchronize). Se o servidor atender ao pedido de conexão, enviará ao computador solicitante um sinal chamado ACK (Acknowledgement). O problema é que em ataques desse tipo, o servidor não consegue responder a todas as solicitações

e então passa a recusar novos pedidos.

Outra forma de ataque comum é o UPD Packet Storm, onde um computador faz solicitações constantes para que uma máquina remota envie pacotes de respostas ao solicitante. A máquina fica tão sobrecarregada que não consegue executar suas funções.

Não são apenas grandes quantidades de pacotes geradas que podem causar um ataque de negação de serviço.

Problemas em aplicativos também podem gerar.

- *Ping da Morte*

14.3.1. Exemplo de ataques DoS

Em Linux:



```
$ :(){ :|:& };;  
$ dd if=/dev/zero of=/var/spool/mail/meu_usuario  
$ perl -e 'while (1) { fork();  
                open $fh, "</proc/meminfo";  
                open $hf, ">/tmp/bla"; }'  
$ dd if=/dev/urandom of=/dev/mem  
$ perl -e 'fork while fork'
```

Em Windows:

- Em um .bat: %0|%0

Ou:



```
:s  
start %0
```

```
goto :s
```

14.3.2. Prática dirigida

- C4

O C4 é uma ferramenta que gera ataques de DoS em redes locais com SYN Flood . Vamos conhecê-la um pouco mais, digitando no terminal:



```
$/c4
```

Com esse comando, teremos como retorno a sintaxe e a explicação resumida dos parâmetros e opções do comando c4.

A sintaxe correta para um ataque de SYN Flood com o c4 contra um host específico é:

Sintaxe: ./c4 -h [ip_alvo]

E alguns dos parâmetros existentes são:

Parâmetros:

-h destination ip/host

-p destination port range [start,end] (defaults to random)

-t attack timeout (defaults to forever)

-l % of box link to use (defaults to 100%)

Vamos formar duplas e realizar ataques de DoS na máquina do companheiro de exercício. Cuidado, pois esse ataque pode travar a máquina do companheiro e até mesmo a sua!

14.4. DDoS

O DDoS, sigla para Distributed Denial of Service, é um ataque DoS ampliado, ou seja, que utiliza até milhares de computadores para atacar um determinado alvo.

Esse é um dos tipos mais eficazes de ataques e já prejudicou sites conhecidos, tais como os da CNN, Amazon, Yahoo, Microsoft e eBay.

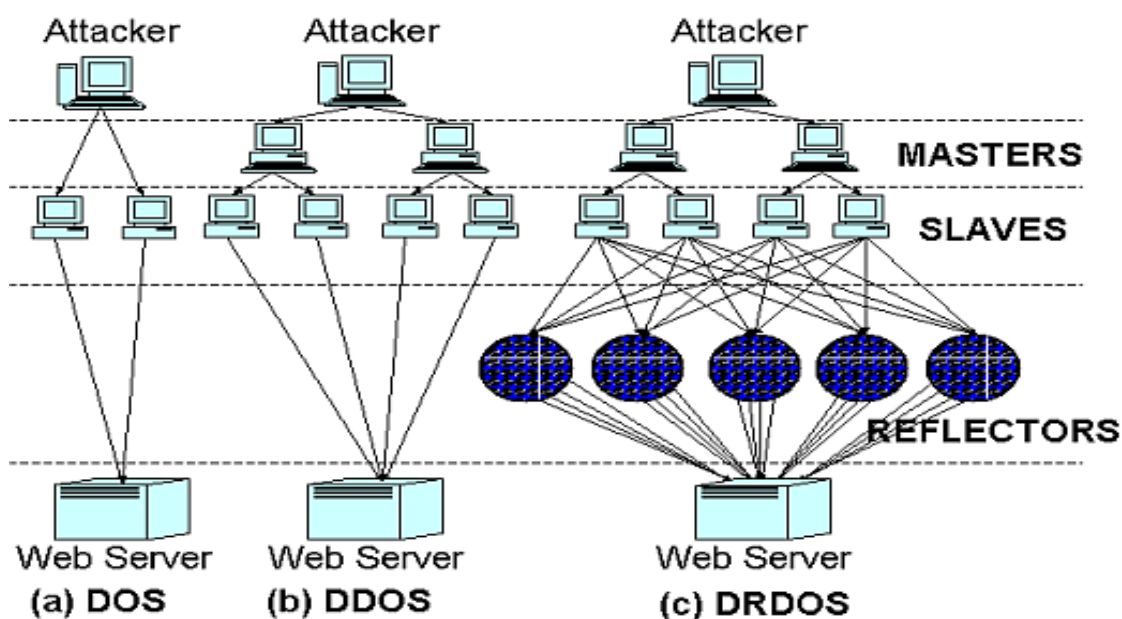
Para que os ataques do tipo DDoS sejam bem-sucedidos, é necessário que se tenha um número grande de computadores para fazerem parte do ataque. Uma das melhores formas encontradas para se ter tantas máquinas, foi inserir programas de ataque DDoS em vírus ou em softwares maliciosos.

Em um primeiro momento, os hackers que criavam ataques DDoS tentavam "escravizar" computadores que agiam como servidores na internet. Com o aumento na velocidade de acesso à internet, passou-se a existir interesse nos computadores dos usuários comuns com acesso banda larga, já que estes representam um número muito grande de máquinas na internet.

Para atingir a massa, isto é, a enorme quantidade de computadores conectados à internet, vírus foram e são criados com a intenção de disseminar pequenos programas para ataques DoS. Assim, quando um vírus com tal poder contamina um computador, este fica disponível para fazer parte de um ataque DoS e o usuário dificilmente fica sabendo que sua máquina está sendo utilizado para tais fins. Como a quantidade de computadores que participam do ataque é grande, é praticamente impossível saber exatamente qual é a máquina principal do ataque.

Quando o computador de um internauta comum é infectado com um vírus com funções para ataques DoS, este computador passa a ser chamado de zumbi. Após a contaminação, os zumbis entram em contato com máquinas chamadas de mestres, que por sua vez recebem orientações (quando, em qual site/computador, tipo de ataque, entre outros) de um computador chamado atacante. Após receberem as ordens, os computadores mestres as repassam aos computadores zumbis, que efetivamente executam o ataque. Um computador mestre pode ter sob sua responsabilidade até milhares de computadores. Repare que nestes casos, as tarefas de ataque DoS são distribuídas a um "exército" de máquinas escravizadas.

Daí é que surgiu o nome Distributed Denial of Service. A imagem abaixo ilustra a hierarquia de computadores usadas em ataques DDoS (além de ilustrar também um ataque DoS e DRDos).



Como exemplo real de ataques DDoS ajudados por vírus, tem-se os casos das pragas digitais Codered, Slammer e MyDoom. Existem outros, mas estes são os que conseguiram os maiores ataques já realizado.

14.4.1. Ferramenta de DDoS

TFN2K

Esta foi a primeira ferramenta de ataque DDoS disponível publicamente. O TFN foi escrito por Mixter. Os ataques efetuados pelo TFN são:

- UDP Flooding;
- TCP SYN Flooding;
- ICMP Flooding;
- e Smurf Attack.

O controle dos mestres é feito por linha de comando, e a execução do

programa deve ser acompanhada dos parâmetros desejados com a sintaxe:

Sintaxe: tfn <iplist> <type> [ip] [port]

Onde:

<iplist> é a lista dos agentes que podem ser utilizados;

<type> é o tipo de ataque desejado;

[ip] é o endereço da vítima;

e [port] é a porta desejada para ataques TCP SYN flooding, que pode ser definida como um número aleatório (parâmetro 0).

O TFN é bastante "discreto". A comunicação entre os mestres e os agentes é feita por mensagens ICMP tipo 0, o que torna difícil o monitoramento dessas comunicações, pois muitas ferramentas de monitoramento não analisam o campo de dados de mensagens ICMP.

14.5. Principais tipos de ataques

14.5.1. Ping Flood

Ping flood é um ataque de negação de serviço simples no qual o atacante sobrecarrega o sistema vítima com pacotes ICMP Echo Request (pacotes ping).

Este ataque apenas é bem sucedido se o atacante possui mais largura de banda que a vítima. Como a vítima tentará responder aos pedidos, irá consumir a sua largura de banda impossibilitando-a responder a pedidos de outros utilizadores.

As únicas maneiras de proteger deste tipo de ataque é limitando o tráfego do ping na sua totalidade ou apenas limitando o tráfego de pacotes ICMP Echo Request com um tamanho menos elevado.


```
luiz@luiz-laptop:~$ ping 127.0.0.1 -s 65507
PING 127.0.0.1 (127.0.0.1) 65507(65535) bytes of data.
65515 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.208 ms
65515 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.201 ms
65515 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.198 ms
65515 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.209 ms
65515 bytes from 127.0.0.1: icmp_seq=5 ttl=64 time=0.206 ms
65515 bytes from 127.0.0.1: icmp_seq=6 ttl=64 time=0.200 ms
^C
--- 127.0.0.1 ping statistics ---
6 packets transmitted, 6 received, 0% packet loss, time 4997ms
rtt min/avg/max/mdev = 0.198/0.203/0.209/0.017 ms
luiz@luiz-laptop:~$
```

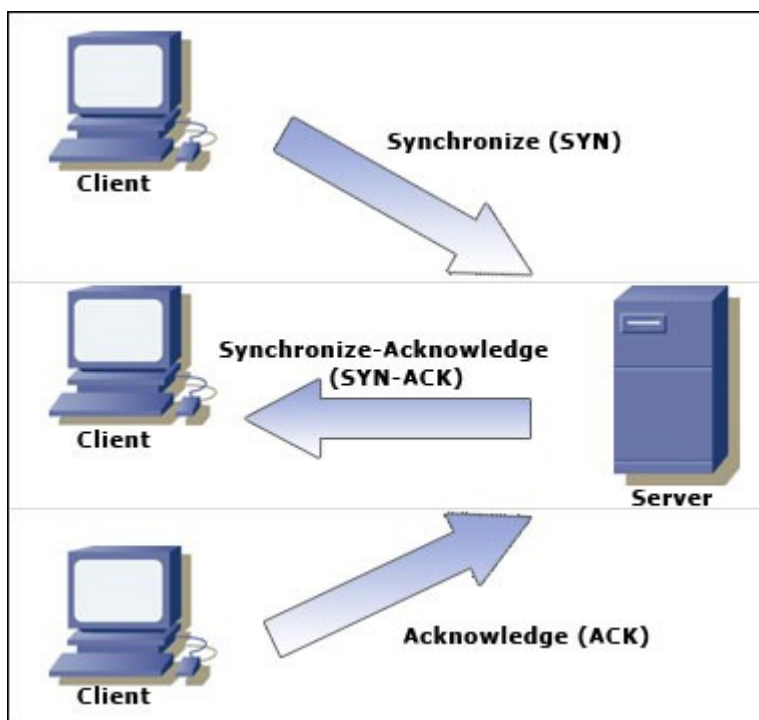
14.5.2. SYN Flood

SYN flood ou ataque SYN é uma forma de (DoS) em sistemas computadorizados, na qual o atacante envia uma seqüência de requisições SYN para um sistema-alvo.

Quando um cliente tenta começar uma conexão TCP com um servidor, o cliente e o servidor trocam um série de mensagens, que normalmente são assim:

- O cliente requisita uma conexão enviando um SYN (synchronize) ao servidor.
- O servidor confirma esta requisição mandando um SYN-ACK(acknowledge) de volta ao cliente.
- O cliente por sua vez responde com um ACK, e a conexão está estabelecida.

Isto é o chamado aperto de mão em três etapas (Three-Way Handshake).



Um cliente malicioso pode não mandar esta última mensagem ACK. O servidor irá esperar por isso por um tempo, já que um simples congestionamento de rede pode ser a causa do ACK faltante.

Esta chamada conexão semi-aberta pode ocupar recursos no servidor ou causar prejuízos para empresas usando softwares licenciados por conexão. Pode ser possível ocupar todos os recursos da máquina, com pacotes SYN. Uma vez que todos os recursos estejam ocupados, nenhuma nova conexão (legítima ou não) pode ser feita, resultando em negação de serviço. Alguns podem funcionar mal ou até mesmo travar se ficarem sem recursos desta maneira.

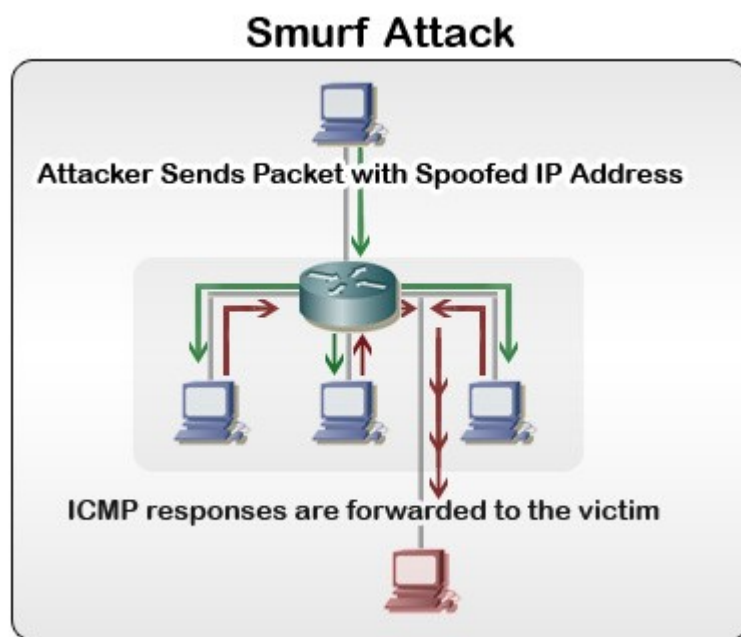
Ao contrário do que muitos pensam, não resolve ataque negação de serviço por Syn flood limitando a quantidade de conexões por minuto (como usar o módulo limit ou recent do iptables), pois as conexões excedentes seriam descartadas pelo firewall, sendo que desta forma o próprio firewall tiraria o serviço do ar. Se eu, por exemplo, limito as conexões SYN a 10/seg, um atacante precisa apenas manter uma taxa de SYNs superior a 10/s para que conexões legítimas sejam descartadas pelo firewall.

O firewall tornou a tarefa do atacante ainda mais fácil. Um ataque de Syn Flood é feito com os IPs forjados (spoof), para que o atacante não receba os Syn-ACKs de suas falsas solicitações.

14.5.3. Smurf Attack

O Smurf é outro tipo de ataque de negação de serviço. O agressor envia uma rápida seqüência de solicitações de Ping (um teste para verificar se um servidor da Internet está acessível) para um endereço de broadcast.

Usando spoofing, o atacante faz com que o servidor de broadcast encaminhe as respostas não para o seu endereço, mas para o da vítima. Assim, o computador-alvo é inundado pelo Ping.



14.6. Recomendações

É sugerido que o Pen-tester seja cauteloso com o uso desse tipo de ataque ou de ferramentas que possam causar uma negação de serviço.

Exceto em casos que o cliente solicite tal tipo de ataque, não devemos realizar esse ataque, pois pode prejudicar os negócios da empresa.

14.7. Sequestro de Sessão

A idéia por detrás do ataque de sequestro de sessão, ou session hijacking, é justamente utilizar credenciais válidas para acessar recursos que não estão disponíveis publicamente.

Um exemplo de session hijacking, é conseguir acessar um servidor SSH a partir de uma sessão aberta de um usuário válido.

Outro exemplo, muito utilizado pela maioria dos atacantes que quer ganhar acesso não-autorizado à contas de usuários, é o sequestro de sessão de aplicações WEB, onde é possível acessar o e-mail, orkut, facebook, conta bancária e burlar qualquer outro tipo de controle de acesso de aplicações online, de forma que possa acessar informações confidenciais do alvo.

A ferramenta utilizada para um ataque de session hijacking de SSH é o sshmitm, instalado a partir da suite dsniff (funciona apenas na versão SSH1).

Sintaxe:

```
sshmitm [-d] [-I] [-p porta] host [porta]
```

Parâmetros:

- -d Enable verbose debugging output.
- -I Monitor / hijack an interactive session.
- -p port Specify the local port to listen on.
- host Specify the remote host to relay connections to.
- port Specify the remote port to relay connections to.

14.7.1. Ferramentas

Outras ferramentas interessantes que podemos citar, são:

- Firesheep
- Session Thief
- Hunt
- Juggernaut
- SSL Strip

14.8. Contramedidas

Infelizmente não existe muito o que fazer para prevenir esse tipo de ataque, quando estamos falando de ataques que envolvem inundação de pacotes. Normalmente, vence quem tem mais link!

Porém, DoS causados por falhas em aplicações podem ser evitadas com treinamento sobre programação segura para os programadores.

Apesar de não existir nenhum meio que consiga impedir totalmente um ataque DoS, é possível detectar a presença de ataques ou de computadores (zumbis) de uma rede que estão participando de um DDoS. Para isso, basta observar se está havendo mais tráfego do que o normal (principalmente em casos de sites, seja ele um menos conhecido, seja ele um muito utilizado, como o Google.com), se há pacotes TCP e UDP que não fazem parte da rede ou se há pacotes com tamanho acima do normal. Outra dica importante é utilizar softwares de IDS (Intrusion Detection System - Sistema de Identificação de Intrusos).

Para prevenção, uma das melhores armas é verificar as atualizações de segurança dos sistemas operacionais e softwares utilizados pelos computadores. Muitos vírus aproveitam de vulnerabilidades para efetuar contaminações e posteriormente usar a máquina como zumbi. Também é importante filtrar certos tipos de pacotes na rede e desativar serviços que não são utilizados.

14.8.1. Find DdoS

É uma ferramenta que foi desenvolvida por um órgão do FBI em função da grande quantidade de ataques DDoS ocorridos. O find_ddos localiza no sistema os masters e agentes das ferramentas Trin00, Tribe Flood Network, TFN2k e Stacheldraht.